Sicurezza dei Sistemi Informativi

Appello d'Esame del 23 Febbraio 2024

Anno Accademico 2023-2024

Politecnico di Torino — Docente: Prof. Cataldo Basile

2024-02-23

1 Testo Ufficiale dell'Esame

Domanda 1: Domande a Scelta Multipla

Valutare la correttezza delle seguenti affermazioni:

a. OpenVPN è un protocollo che può essere usato in alternativa ad IPsec per creare Virtual Private Network a livello 2 o 3.

b. L'attacco di Kaminsky contro il DNS può essere mitigato efficacemente mediante l'impiego di IPsec.

c. Lo standard Common Criteria prevede che la valutazione della sicurezza avvenga rispetto a un Security Target (ST).

d. I sistemi legacy vulnerabili dovrebbero essere sempre i primi ad essere patchati in una strategia di patch management, senza effettuare test preventivi.

Domanda 2: Standard Common Criteria (ISO/IEC 15408)

Spiegare cosa sono i **Common Criteria** e a cosa servono.

- Descrivere quali caratteristiche ereditano dai precedenti standard (TCSEC, ITSEC) e le peculiarità che li rendono più flessibili e funzionali;
- Spiegare cosa sono il **Target of Evaluation (TOE)**, il **Protection Profile (PP)** e il **Security Target (ST)**;
- Illustrare i livelli di garanzia **EAL (Evaluation Assurance Level)** da 1 a 7;
- Discutere quali sono i tre attori principali coinvolti nel processo di certificazione e come si garantisce l'indipendenza e il mutuo riconoscimento internazionale (CCRA).

Domanda 3: Architettura DMZ e Filtraggio URL HTTPS

Spiegare cosa è una DMZ (*Demilitarized Zone*) e in che modo può essere creata (router a tre gambe vs architettura dual-firewall con due firewall di vendor differenti). Discutere delle motivazioni di sicurezza che portano alla scelta di una DMZ. Supponendo che il traffico da filtrare sia quello diretto verso la URL sicura:

`https://web.azienda.it/servizio/segreto`

Spiegare perché un packet filter tradizionale non può applicare questo filtro e descrivere

la soluzione tecnologica adeguata (Reverse Proxy con terminazione TLS e ispezione L7).

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Valutazione Crocette

- **a. VERA**: OpenVPN opera nello spazio utente sfruttando interfacce virtuali TUN (livello 3 - IP) o TAP (livello 2 - Ethernet), incapsulando il traffico in tunnel TLS su UDP o TCP come alternativa flessibile a IPsec.
- **b. FALSA**: L'attacco di Kaminsky è un attacco di avvelenamento della cache DNS (*DNS Cache Poisoning*) che sfrutta l'insufficienza di entropia nei Transaction ID delle query DNS. La contromisura standard corretta è **DNSSEC** (firme digitali asimmetriche sui record DNS), mentre IPsec opera a livello 3 e non risolve la falsificazione delle risposte dei server DNS ricorsivi non autenticati.
- **c. VERA**: Nei Common Criteria, il Target of Evaluation (TOE) viene valutato a fronte del suo specifico Security Target (ST), che descrive i requisiti funzionali e di garanzia.
- **d. FALSA**: I sistemi legacy sono spesso fragili e l'applicazione cieca di patch senza collaudo in ambiente di staging può causare interruzioni critiche di servizio (*service outage*). NIST SP 800-40 raccomanda un'attenta prioritizzazione basata sul rischio e test di compatibilità.

Soluzione Domanda 2: Common Criteria (ISO/IEC 15408)

Origine ed Eredità: I Common Criteria hanno unificato gli standard precedenti: dal TCSEC americano hanno ereditato il rigore sui modelli formali di sicurezza, mentre dall'ITSEC europeo hanno ereditato la **separazione categorica tra Requisiti Funzionali di Sicurezza (SFR - Security Functional Requirements)** e **Requisiti di Garanzia/Correttezza (SAR - Security Assurance Requirements)**.
Concetti Chiave:

- **TOE (Target of Evaluation)**: Il prodotto o sistema software/hardware sottoposto a valutazione.
- **Protection Profile (PP)**: Documento indipendente dall'implementazione che definisce le esigenze di sicurezza per una classe specifica di prodotti (es. smart card, firewall, sistemi operativi).
- **Security Target (ST)**: Documento che descrive le caratteristiche di sicurezza dello specifico TOE sottoposto a certificazione.
- **EAL (Evaluation Assurance Level)**: Scala da EAL1 (funzionalmente testato) a EAL7 (progettazione verificata formalmente e testata). EAL4 è il livello massimo commercialmente conveniente senza richiedere costosi modelli matematici formali.

I Tre Attori del Processo:

1. **Sponsor / Developer**: L'azienda che sviluppa il prodotto e commissiona la valutazione.
2. **Evaluation Facility (Laboratorio Indipendente)**: Laboratorio terzo accreditato che esegue i test tecnici seguendo rigorosamente la Common Evaluation Methodology (CEM).

3. **Certification Body (Organismo di Certificazione Nazionale)**: Ente pubblico governativo che supervisiona la valutazione e rilascia il certificato formale.

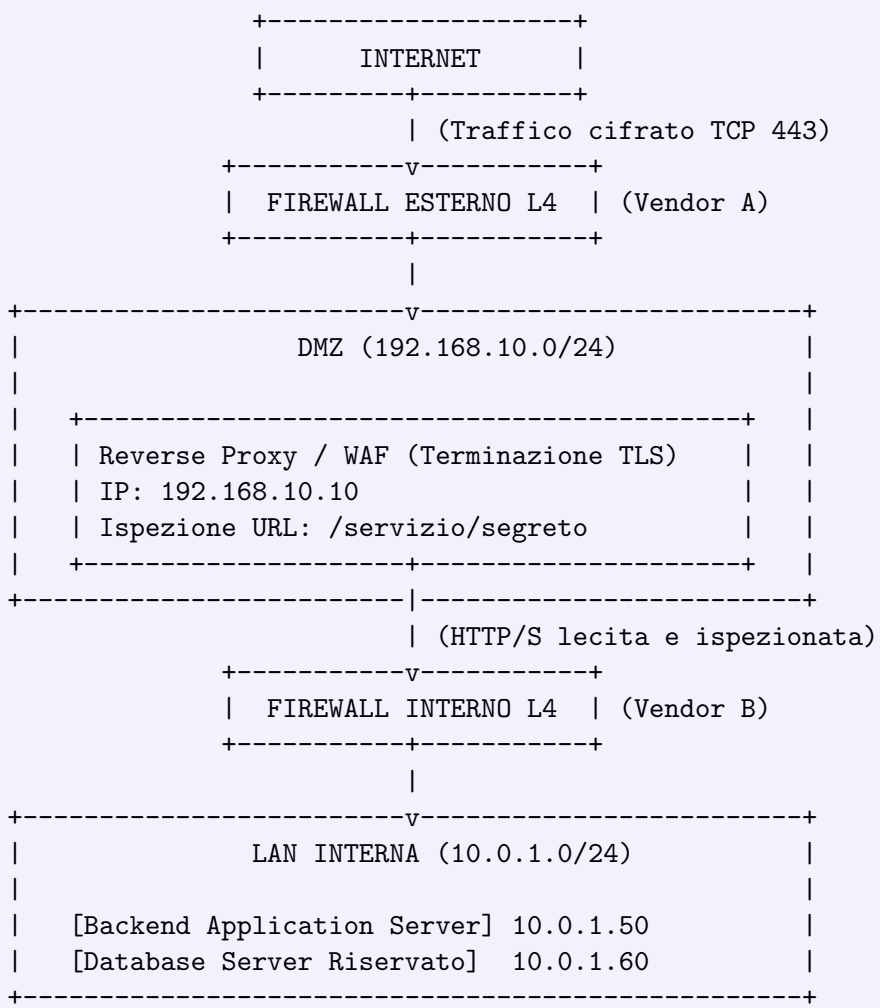
Il trattato internazionale **CCRA (Common Criteria Recognition Arrangement)** garantisce che un certificato rilasciato da uno stato membro sia riconosciuto validamente in tutti gli altri stati firmatari.

Soluzione Domanda 3: Architettura DMZ e Filtraggio URL HTTPS

Creazione della DMZ e Architetture a Confronto: Una Demilitarized Zone (*DMZ*) è una sottorete perimetrale cuscinetto che separa la rete pubblica non fidata (Internet) dalla rete interna protetta (LAN):

- *Router/Firewall a tre gambe (Three-Homed Router)*: Un unico apparato gestisce tre interfacce (Esterna/Internet, DMZ, Interna/LAN). È economico ma costituisce un singolo punto di fallimento (*Single Point of Failure*).
- *Architettura Dual-Firewall (Two-Tier Screened Subnet)*: Due firewall distinti in serie (preferibilmente di vendor differenti per evitare che un'unica vulnerabilità zero-day li comprometta entrambi): il firewall esterno scherma la DMZ da Internet, il firewall interno scherma la LAN aziendale dalla DMZ.

Topologia di Rete (Architettura Two-Tier con Reverse Proxy L7):



Impossibilità per un Packet Filter Tradizionale: Un packet filter operante a livello di trasporto/rete (L3/L4) analizza solo gli header IP (indirizzi sorgente/destinazione) e TCP (porte e flag):

1. L'intera richiesta HTTP (incluso il metodo `GET/POST`, il percorso URL sensibile `/servizio/segreto`, i campi header e l'eventuale payload) viaggia **completamente cifrata** all'interno del payload TLS (*Record Layer*).

2. Il packet filter vede unicamente segmenti TCP diretti alla porta di destinazione 443; non può accedere al payload in chiaro senza rompere il canale crittografico e non è pertanto in grado di discriminare una richiesta verso l'URL pubblica `https://web.azienda.it/` da quella verso l'endpoint confidenziale `/servizio/segreto`.

Soluzione Tecnologica (Reverse Proxy L7 con Terminazione TLS): Si posiziona nella DMZ un **Reverse Proxy / WAF** (es. Nginx, Envoy o un'applicazione dedicata in Rust) che possiede il certificato digitale X.509 e la chiave privata del server:

1. Il client esterno completa l'handshake TLS direttamente con il Reverse Proxy.

2. Il proxy decifra la richiesta HTTP, ne esegue il parsing sintattico ed estrae il path URL richiesto.

3. Se la richiesta corrisponde all'URI protetta `/servizio/segreto`, il proxy applica i controlli di autorizzazione avanzati (es. verifica di mutua autenticazione mTLS con certificato client o validazione di token JWT/OAuth2).

4. Solo in caso di autorizzazione confermata, il proxy inoltra la richiesta al Server Backend interno via connessione cifrata dedicata. In caso contrario, risponde con codice `403 Forbidden` o `401 Unauthorized`, bloccando l'attacco prima che raggiunga la LAN interna.

Alternative Implementation Note: Concorrenza Rust per l'Ispezione L7

In un reverse proxy ad alte prestazioni scritto in Rust:

- Si utilizza `rustls` con backend asincrono `tokio`, beneficiando della memoria memory-safe che elimina alla radice vulnerabilità di tipo buffer overflow, use-after-free e memory leak.

- `std::sync::Arc<rustls::ServerConfig>`: La configurazione TLS (certificati, ciphersuite consentite) viene condivisa in sola lettura tra tutti i task asincroni con overhead nullo.